

Scenario 02 — SmartGrid Meter (Energy)

Deliberately vulnerable smart-meter management stack for the CyberFort cyber range. Trainees use CyberFort to scan the IT **and** OT ports, run a Semgrep + OSV audit on the source, complete a NIS2 Article 21 assessment, and produce a PDF readiness report.

What's in the box

```
02-smartgrid-meter-energy/
├─ README.md           ← this file
├─ docker-compose.yml  ← 4-service stack
├─ admin/              ← Flask management UI (intentionally vulnerable)
├─ modbus/             ← pymodbus TCP simulator, 3 slaves
├─ mosquitto/          ← Mosquitto broker, anonymous mode ON
├─ telemetry/          ← MQTT publisher with hardcoded creds
└─ docs/
   ├── TRAINEE_HANDBOOK.md
   ├── INSTRUCTOR_GUIDE.md
   └── NIS2_CONTROL_MAPPING.md
```

Topology

- **VM1** — CyberFort (:5173 , :8000 , scanners on :8010-:8013).
- **VM2** — this scenario. Exposes **8080** (HTTP), **1883** (MQTT), and **5020** (Modbus TCP).

Deploy on VM2

```
git clone <repo-url> /srv/smartgrid-scenario
cd /srv/smartgrid-scenario/02-smartgrid-meter-energy
docker compose up -d --build
docker compose ps          # expect all four services Up
```

What the trainee should see

- Nmap reports three open ports (8080, 1883, 5020).
- `mosquitto_sub -h <VM2> -p 1883 -t 'smartgrid/#' -v` returns live telemetry.
- A pymodbus client reads holding registers from slave IDs 1, 2, 3 without authentication.
- ZAP flags default `admin/admin` credentials and an unrestricted file upload on `/firmware`.
- Semgrep flags hardcoded credentials in `telemetry/publisher.py` and `admin/meter_admin/config.py`.
- OSV flags Flask 2.0.1, Werkzeug 2.0.1, pymodbus 2.5.3, paho-mqtt 1.5.1, requests 2.25.0.

Full walkthrough in [docs/TRAINEE_HANDBOOK.md](#).

Safety

Deliberately vulnerable. Run only on an isolated cyber-range network.